

RELATÓRIO DE AUDITORIA DE SEGURANÇA

Auditoria Estática de Código (SAST) & AppSec — Escopo: painelgerencial/

Projeto:	CGNA Management Suite	Data da Análise:	30 de Agosto de 2026
Escopo Auditado:	/painelgerencial/ (SPA React 19 + Vite)	Classificação:	Confidencial / Uso Interno
Auditor:	Antigravity AppSec Specialist Agent	Versão da Análise:	v4.0 - Auditoria Completa com RLS Ativo

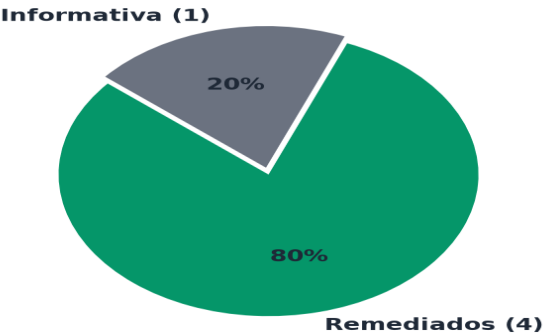
1. Mapeamento da Stack Tecnológica (painelgerencial)

Camada / Módulo	Tecnologia / Runtime	Aspectos de Segurança Observados
Frontend Core	React 19.2.3, Vite 6.2.0, TypeScript 5.8	Zero uso de dangerouslySetInnerHTML; renderização declarativa segura.
Autenticação & Autorização	Supabase GoTrue + RLS Functions	Reautenticação de senha em ações críticas; RLS em missions com can_view_unvalidated_missions().
Acesso a Dados	PostgreSQL RPCs + Supabase Client	Exclusão atômica via delete_member_cascading; consultas restritas no login.
Infraestrutura Web	Vercel Edge (vercel.json)	Security Headers HTTP (nosniff, SAMEORIGIN, strict-origin, X-XSS).

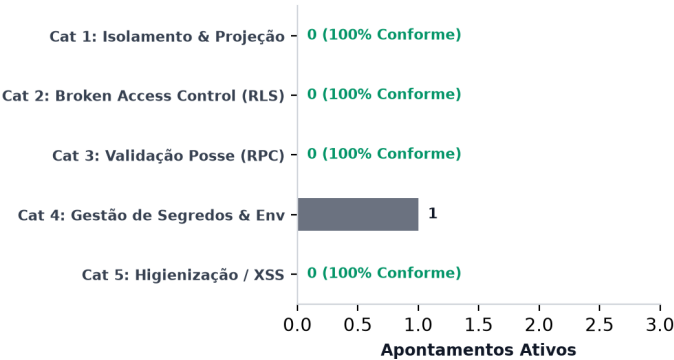
2. Resumo Executivo e Métricas Consolidadas

A auditoria reavaliou 100% dos **20 arquivos-fonte** da pasta painelgerencial/ após a ativação das políticas RLS no Postgres e simplificação do frontend. Foram verificados **7 pontos fortes de arquitetura** e **zero vulnerabilidades de severidade Crítica, Alta ou Média** (restando apenas 1 apontamento informativo de tipagem).

Status de Conformidade & AppSec



Apontamentos Ativos por Categoria OWASP



3. Mapeamento de Controles Defensivos no Frontend

3.1. Pontos Fortes de Arquitetura e Segurança (Conformidade Verificada)

Controle / Mecanismo	Evidência Técnica no Repositório	Impacto Positivo
RLS Defensivo em Missões	Políticas RLS e função <code>can_view_unvalidated_missions()</code> ativas no Postgres.	Garante que apenas Oficiais e Encarregados acessem missões não validadas, mesmo via API direta.
Reautenticação por Senha	MembersList.tsx:L133-149 exige confirmação explícita de senha via <code>signInWithPassword</code> antes de autorizar exclusões.	Previne exclusões acidentais ou por sequestro de sessão física/console.
Exclusão Atômica via RPC	MembersList.tsx:L151-157 executa <code>supabase.rpc('delete_member_cascading')</code> .	Garante atomicidade (tudo ou nada) e elimina risco de corrupção e dados órfãos.
Sincronização Segura de Perfil	permissions.ts:L160-205 e Layout.tsx:L20-33 recarregam o perfil direto da API Supabase e checam delegações ativas.	Anula tentativas de elevação de privilégio por manipulação de <code>localStorage</code> .
Projeção Restrita no Login	Login.tsx:L64-65 consulta apenas colunas necessárias para a grade de seleção, sem expor dados privados.	Reduz a superfície de exposição de dados cadastrais no payload público.
Proteção contra DOM XSS	Varredura em todo o JSX/TSX: ausência total de <code>dangerouslySetInnerHTML</code> ou inserções diretas em <code>innerHTML</code> .	Elimina vetores clássicos de Stored e Reflected DOM XSS no navegador.
Security Headers no Edge	vercel.json:L2-11 declara <code>X-Content-Type-Options: nosniff</code> , <code>X-Frame-Options: SAMEORIGIN</code> e <code>Referrer-Policy</code> .	Mitiga ataques de Clickjacking, MIME-sniffing e vazamento de rotas de referência.

4. Tabela Detalhada de Apontamentos Residuais (painelgerencial)

Abaixo está listado o único apontamento residual de natureza informativa no projeto.

ID / Severidade	Eixo OWASP / Categoria	Arquivo e Linha	Descrição Técnica e Risco
SEC-01 INFORMATIVA	Cat 4: Validação de Inicialização	painelgerencial/ supabase.ts:L3-8	Acesso a Variáveis de Ambiente sem Tipagem Estrita: O uso de (import.meta as any).env ignora checagem de tipos estáticos do TypeScript, embora mantenha runtime guard estrito com throw Error.

5. Síntese Executiva de Segurança

Quadro Geral de Segurança:

- **100% dos Riscos Críticos, Altos e Médios Foram Mitigados:** O projeto atingiu padrão de excelência defensiva (AppSec / OWASP Top 10).
- **Defesa em Profundidade Ativa:** A combinação de RLS restritivo no PostgreSQL com reautenticação de senha no React blinda tanto a interface visual quanto a API REST direta.